

WORDPRESS VULNERABILITY RESEARCH AND TESTING

INTRODUCTION

A Content Management System (CMS) is a software platform that helps users create, manage, and modify website content without needing in-depth programming knowledge. CMS platforms are widely used because they simplify website development, support plugins and themes, and allow non-technical users to build fully functional websites efficiently.

Among all CMS platforms, WordPress stands out as the most popular. It is an open-source CMS that powers millions of websites globally due to its flexibility, ease of use, and vast plugin ecosystem. However, its widespread adoption also makes it a frequent target for cyberattacks.

1. What is CMS and Why Do People Use It?

A CMS (Content Management System) is software that allows users to create, manage, and modify website content without needing to write code from scratch.

It simplifies web publishing and is used by bloggers, businesses, developers, and organizations to maintain websites efficiently.

Why people use CMS:

- Easy content editing (No coding needed)
- Flexible plugins and themes
- Supports multi-user access
- SEO and performance tools
- Fast deployment of websites

2. What is WordPress?

WordPress is the most popular open-source CMS used globally, powering over 40% of websites on the internet. It is built with PHP and MySQL, and offers thousands of plugins and themes for customization.

Key benefits:

- Free and open-source
- User-friendly dashboard
- Extensible with plugins/themes
- Active community and support

3. Common WordPress Vulnerabilities & How to Identify Them?

Vulnerability	Identification Method
Outdated Plugins/Themes	Use WPScan or manual checking /wp-content/plugins/
Exposed WP Admin Panel	Detect via /wp-admin or /wp-login.php access
Information Disclosure	Use headers, readme.txt, or license.txt files
Directory Listing	Check for open /wp-content/uploads/ or /wp-includes/
User Enumeration	Try URLs like /?author=1, analyze responses

Tools Used:

- WPScan
- WhatCMS
- BuiltWith
- Burp Suite (Passive Scanning)
- Manual Google Dorking

4. Practical: Vulnerability Findings (Screenshots Attached)

1. Wordlift (AI-powered SEO)

```

[!] 2 vulnerabilities identified:
[!] Title: WordLift - AI powered SEO - Schema ≤ 3.54.0 - Missing
Authorization to Authenticated (Subscriber+) Settings Update
References:
- https://wpscan.com/vulnerability/e949e071-67e4-4b21-a361-95
ac55fd41c1
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-121
76
- https://www.wordfence.com/threat-intel/vulnerabilities/id/c
a6bdde6-f381-4ccb-8984-519cf9aca0b1
[!] Title: WordLift ≤ 3.54.5 - Missing Authorization
Fixed in: 3.54.5
References:
- https://wpscan.com/vulnerability/9c51b12c-2028-49d4-ad5e-18
6f8271bd8
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-306
24
- https://patchstack.com/database/wordpress/plugin/wordlift/v
ulnerability/wordpress-wordlift-3-54-4-broken-access-control-vulnerab
ility
Version: 3.40.2 (60% confidence)
Found By: Query Parameter (Passive Detection)
- https://www.wordfence.com/threat-intel/vulnerabilities/id/c
a6bdde6-f381-4ccb-8984-519cf9aca0b1
Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
- https://www.wordfence.com/threat-intel/vulnerabilities/id/c
a6bdde6-f381-4ccb-8984-519cf9aca0b1

```

- **Vulnerable Version:** ≤ 3.54.0
Type: Missing Authorization (Settings Update)
Impact: Subscriber+ users modify settings.
- **Vulnerable Version:** ≤ 3.54.5
Type: Missing Authorization
Impact: Broken access control.
- **Detected Version:** 3.40.2 (60% confidence)

2. MonsterInsights (Google Analytics by MonsterInsights)

```

[!] 3 vulnerabilities identified:
[!] Title: MonsterInsights < 8.12.1 - Contributor+ Stored XSS
Fixed in: 8.12.1
References:
- https://wpscan.com/vulnerability/22903c-4901-9404-3008750c14
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-0031
[!] Title: Google Analytics by Monster Insights < 8.14.1 - Contributor+ Stored XSS
Fixed in: 8.14.1
References:
- https://wpscan.com/vulnerability/22903c-4901-9404-3008750c14
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-0031
[!] Title: Google Analytics by Monster Insights < 8.22.0 - Missing Authorization
Fixed in: 8.22.0
References:
- https://wpscan.com/vulnerability/22903c-4901-9404-3008750c14
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2022-0031
- https://www.wordfence.com/threat-intel/vulnerabilities/id/8d867d91eb7
- https://www.wordfence.com/threat-intel/vulnerabilities/id/8d867d91eb7
Version: 8.10.0 (100% confidence)
Found By: Monster Insights Comment (Passive Detection)
Confirmed By: Readme - Stable Tag (Aggressive Detection)
https://www.readme.com/docs/monster-insights-plugin/google-analytics

```

- **Vulnerable Version:** < 8.12.1
Type: Contributor+ Stored XSS
Impact: Malicious script injection by low-privileged users.
- **Vulnerable Version:** < 8.14.1
Type: Contributor+ Stored XSS
Impact: Arbitrary JavaScript execution.
- **Vulnerable Version:** < 8.22.0
Type: Missing Authorization
Impact: Unauthorized access to restricted features.
- **Detected Version:** 8.10.0 (100% confidence)

3. WPBakery Page Builder (Visual Composer)

```

[!] Title: WPBakery < 7.8 - Authenticated (Author+) Local File Inc
lusion
Fixed in: 7.8
References:
- https://wpscan.com/vulnerability/ab8c6c9acd
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-4969
- https://www.wordfence.com/threat-intel/vulnerabilities/id/77
[!] Title: WPBakery Page Builder < 8.5 - Authenticated (Author+) S
tored Cross-Site Scripting via Grid Builder
Fixed in: 8.5
References:
- https://wpscan.com/vulnerability/0e2988f051
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-4965
- https://www.wordfence.com/threat-intel/vulnerabilities/id/a
[!] Title: WPBakery Page Builder < 8.5 - Authenticated (Contributo
r+) Stored Cross-Site Scripting via Multiple Page Builder Elements
Fixed in: 8.5
References:
- https://wpscan.com/vulnerability/053a5c2e4e
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2025-4968
- https://www.wordfence.com/threat-intel/vulnerabilities/id/1
Version: 6.0.5 (80% confidence)
Found By: Body Tag (Passive Detection)
- https://www.bayfront-inn.com/, Match: 'js-comp-ver-6.0.5'

```

```

[!] Title: WPBakery Visual Composer < 7.6 - Authenticated (Contrib
utor+) Stored Cross-Site Scripting via Button onclick attribute
Fixed in: 7.6
References:
- https://wpscan.com/vulnerability/74e6722-d293-4572-80bf-984e74c3e33f
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-1805
- https://www.wordfence.com/threat-intel/vulnerabilities/id/7a571386-fae1-4a56-8567-9d3e23249de1
[!] Title: WPBakery Visual Composer < 7.6 - Authenticated (Contrib
utor+) Stored Cross-Site Scripting via Post Author
Fixed in: 7.6
References:
- https://wpscan.com/vulnerability/ae96ba23ae
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-1840
- https://www.wordfence.com/threat-intel/vulnerabilities/id/cb8ecbbc-ada9-4887-92e6-25a587ecfb84
[!] Title: WPBakery Page Builder < 7.7 - Authenticated (Contributo
r+) Stored Cross-Site Scripting via VC Single Image link attribute
Fixed in: 7.7
References:
- https://wpscan.com/vulnerability/04af6256c8
- https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2024-5265
- https://www.wordfence.com/threat-intel/vulnerabilities/id/35a5114e-5c5f-4003-8bb3-77243ffbaca1a

```

- **Vulnerable Version:** < 7.6
Type: Stored XSS (Button onclick & Post Author)
Impact: Contributor+ users inject scripts (bayfront4.jpg.jpg).
- **Vulnerable Version:** < 7.7
Type: Stored XSS (Single Image link)
Impact: Script injection via image links (bayfront4.jpg.jpg).
- **Vulnerable Version:** < 7.8
Type: Local File Inclusion (LFI)
Impact: Author+ users read server files (bayfront3.jpg.png).

- **Vulnerable Version:** < 8.5
Type: Stored XSS (Grid Builder & elements)
Impact: Contributor+/Author+ XSS attacks (bayfront3.jpg.png).
- **Detected Version:** 6.0.5 (80% confidence)

4. Smart Slider 3

```

| Found By: Urls In Homepage (Passive Detection)
|
| [!] 1 vulnerability identified:
|
| [!] Title: Smart Slider 3 < 3.5.0.9 - Authenticated Stored Cross-S
ite Scripting (XSS)
|   Fixed in: 3.5.0.9
|   References:
|     - https://wpscan.com/vulnerability/7b32a782-eb11-4ce3-b94f-b
c10c62-5/d
|     - https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2020-2413
|     - https://www.exploit-db.com/exploits/47455/
|     - https://smartslider.helpscoutdocs.com/article/1740-4-long-16
g
|     - https://packetstormsecurity.com/files/152002/
|
| The version could not be determined.

```

- **Vulnerable Version:** < 3.5.0.9
Type: Authenticated Stored XSS
Impact: Script injection by authenticated users.
- **Detected Version:** Unknown (version not found).

CONCLUSION

WordPress, being the most widely used CMS, is often targeted by attackers due to its vast plugin and theme ecosystem. Through this task, I learned how critical it is to identify and secure vulnerable WordPress components. By conducting real-time assessments on selected targets, I was able to recognize common misconfigurations and outdated elements that could lead to exploitation. This hands-on experience enhanced my understanding of WordPress security and emphasized the importance of responsible vulnerability disclosure in professional cybersecurity practice.